

TP4, eleve : Controle d'accès (OWASP A01)

- Jour 2 - Duree : ~1h15 - Dossier : `jour2-ctf/` (port 8002)

Contexte

A01 est le risque numero 1 de l'OWASP Top 10 2021 : etre autorise a faire ce qu'on ne devrait pas. Etre authentifie (connecte) ne veut pas dire etre autorise (avoir le droit sur une ressource precise).

Mise en place

La stack du Jour 2 doit tourner (`cd jour2-ctf && docker compose up -d --build`).

Challenges

01 - Le profil du capitaine (IDOR)

Objectif : acceder au profil d'un utilisateur qui n'est pas le votre. - Indice 1 : l'API expose les profils via un identifiant dans l'URL. - Indice 2 : que se passe-t-il si vous changez cet identifiant ? - Indice 3 : le serveur verifie-t-il que la ressource vous appartient, ou juste que vous etes connecte ?

11 - La cale aux tresors (path traversal)

Objectif : lire un fichier en dehors du dossier prevu pour les telechargements. - Indice 1 : le telechargement de brochure prend un nom de fichier en parametre. - Indice 2 : que se passe-t-il si ce nom contient `../` ? - Indice 3 : il existe aussi un fichier cache (commencant par un point) dans le dossier servi.

04 - La trappe oubliee (endpoint de debug expose)

Objectif : trouver une porte de service laissee ouverte en production. - Indice 1 : revoyez votre cartographie du TP1. - Indice 2 : certaines routes utiles au developpement ne devraient jamais rester en prod. - Indice 3 : son nom est explicite.

Outils

Burp Repeater (ideal pour muter un identifiant ou un chemin), `curl`.

Validation

Soumettez chaque flag sur <http://localhost:8002/scoreboard>.

Livrable attendu

Pour chaque challenge : le payload, la cause racine, et le niveau auquel on corrige (code / archi / orga).